

SIMATS ENGINEERING
ASSESSMENT TOOL 3 – CASE STUDY

COURSE CODE: ITA14

COURSE NAME: Ethical Hacking

COURSE OUTCOME COVERED

CO4: Implement network security testing methods by performing web server attacks, analyzing web

application vulnerabilities, and assessing wireless network security using Kali Linux. (BT4, BT5)

Assessment Tool Weightage: 35%

QUESTIONS: 5

Total Marks:100

1. A mid-sized e-commerce company hosts its web application on an Apache server running on a Linux environment. Recently, customers reported unauthorized transactions and abnormal account activities. Upon investigation, the IT team discovered suspicious HTTP requests in server logs, including attempts to access hidden directories and injection of malicious scripts into input fields. Additionally, the server is running an outdated version with known vulnerabilities, and no Web Application Firewall (WAF) is implemented. As a cybersecurity analyst, you are tasked with conducting a comprehensive security assessment using Kali Linux. Analyze the possible attack vectors exploited by the attacker, including web server vulnerabilities, input validation issues, and outdated software components. Explain in detail how you would perform reconnaissance, vulnerability scanning, and exploitation using appropriate Kali Linux tools. Further, propose a layered defense strategy that includes server hardening, secure coding practices, and network-level protections to prevent such incidents in the future.

Answer:

SECURITY ASSESSMENT OF AN E-COMMERCE WEB APPLICATION USING KALI LINUX

Introduction

The e-commerce company hosts its web application on an Apache web server running on a Linux operating system. Recently, customers have reported unauthorized transactions and abnormal account activities. The investigation has identified suspicious HTTP requests, attempts to access hidden directories, malicious scripts being entered into input fields, outdated server software, and the absence of a Web Application Firewall (WAF). These weaknesses provide attackers with several opportunities to compromise the web application and customer information.

A comprehensive security assessment should therefore be performed to identify the attack vectors, determine their impact, and recommend appropriate security controls. Kali Linux provides several tools such as Nmap, WhatWeb, Nikto, Gobuster, Burp Suite, SQLmap, and Nuclei that can be used for reconnaissance, vulnerability identification, and controlled validation.

1. Reconnaissance

Reconnaissance is the first phase of the security assessment. The objective is to collect information about the target server, its IP address, open ports, services, operating system, web technologies, and Apache version.

Nmap can be used to identify open ports and running services. WhatWeb can identify the technologies used by the web application, while Curl can be used to inspect HTTP headers.

Commands used during reconnaissance are:

```
nmap -sV -sC TARGET_IP
```

```
whatweb http://TARGET_IP
```

```
curl -I http://TARGET_IP
```

The information collected during this phase helps the security analyst understand the attack surface of the application.

2. Web Server Vulnerability Assessment

The Apache server is reportedly running an outdated version. Outdated software may contain publicly known vulnerabilities that attackers can exploit to gain unauthorized access or obtain sensitive information.

Nikto can be used to identify common web-server vulnerabilities and configuration problems.

```
nikto -h http://TARGET_IP
```

Nmap can also be used to determine the Apache version.

```
nmap -sV TARGET_IP
```

The identified Apache version can then be checked against known vulnerabilities using SearchSploit.

```
searchsploit apache
```

If an outdated version is identified, it should be upgraded to the latest supported and security-patched version.

3. Hidden Directory and File Enumeration

The suspicious requests found in the server logs indicate that attackers may have attempted to discover hidden directories and files. Such resources may contain backup files, administrative interfaces, configuration files, or old application versions.

Gobuster can be used to identify publicly accessible directories and files.

```
gobuster dir -u http://TARGET_IP -w /usr/share/wordlists/dirb/common.txt
```

Additional file extensions can also be tested.

```
gobuster dir -u http://TARGET_IP -w /usr/share/wordlists/dirb/common.txt -x php,html,txt,bak,old
```

The discovered directories should be reviewed by the administrator. Sensitive files and administrative interfaces should not be accessible to unauthorized users.

4. SQL Injection Assessment

SQL Injection is a major threat to an e-commerce application because the application may store customer information, account details, orders, and transaction records in a database. If user input is directly included in SQL queries without proper validation, an attacker may manipulate the query and access unauthorized information.

SQLmap can be used to test an authorized application parameter for SQL injection.

```
sqlmap -u "http://TARGET_IP/product.php?id=1" -p id --batch
```

If SQL injection is confirmed in the controlled testing environment, SQLmap can be used to identify database names.

```
sqlmap -u "http://TARGET_IP/product.php?id=1" --dbs --batch
```

SQL injection can result in loss of confidentiality because customer information may be exposed. It can also affect integrity if unauthorized users are able to modify application or transaction data.

5. Cross-Site Scripting Assessment

The malicious scripts discovered in input fields indicate a possible Cross-Site Scripting vulnerability. XSS occurs when an application accepts user-controlled data and displays it in a web page without proper output encoding.

A harmless test payload can be entered into an authorized test application:

The analyst can check whether the application displays the input as normal text or executes it as JavaScript. Burp Suite can be used to intercept the request and modify the input during testing.

XSS can allow attackers to execute malicious JavaScript in another user's browser. Depending on the vulnerability, an attacker may steal session information, modify displayed content, redirect users to malicious websites, or perform unauthorized actions.

6. Burp Suite Analysis

Burp Suite is useful for analyzing the communication between the browser and the web application. It can intercept HTTP requests and responses and allows the security analyst to modify parameters in a controlled environment.

Burp Suite can be started in Kali Linux using:

```
burpsuite
```

The browser is configured to use the Burp proxy, normally through 127.0.0.1:8080. The analyst can then access the application and observe requests through the HTTP history section. Requests can be sent to Repeater for manual testing of parameters, authentication, session management, and authorization.

Burp Suite can help identify insecure cookies, missing security headers, weak authentication mechanisms, improper input validation, and authorization problems.

7. Vulnerability Scanning

Additional automated scanning can be performed using Nuclei.

```
nuclei -u http://TARGET_IP
```

The results from Nmap, Nikto, Gobuster, Nuclei, Burp Suite, and SQLmap should be compared. Automated scanner results should always be manually validated before being reported as confirmed vulnerabilities.

8. Possible Attack Chain

The attacker may first perform reconnaissance against the public e-commerce application to identify the server IP address, open ports, Apache version, directories, and application technologies. The attacker may then enumerate hidden directories and identify vulnerable application pages.

If the Apache server is outdated, the attacker may attempt to exploit a known server vulnerability. Alternatively, the attacker may target application-level weaknesses such as SQL Injection or XSS.

Through SQL Injection, the attacker may gain unauthorized access to customer or transaction information. Through XSS, malicious scripts may be executed in the browsers of customers. If authentication and session management are also weak, attackers may compromise user accounts and perform unauthorized transactions.

9. Impact on the CIA Triad

The vulnerabilities can affect confidentiality, integrity, and availability.

Confidentiality is affected when attackers obtain customer names, addresses, account information, passwords, order details, or transaction information without authorization.

Integrity is affected when attackers modify customer records, orders, account information, or transactions. Unauthorized transactions are a direct example of an integrity violation.

Availability may be affected if attackers exploit server vulnerabilities, modify important application resources, overload the server, or cause the application to become unavailable.

Therefore, the identified vulnerabilities represent a significant risk to the organization and its customers.

10. Server Hardening

The Apache server should be regularly updated with the latest security patches. Unnecessary services and modules should be disabled. Directory listing should be disabled, and sensitive configuration and backup files should be removed from publicly accessible directories.

The server configuration should be checked using:

```
apache2ctl configtest
```

The Apache service should be restarted after approved configuration changes:

```
systemctl restart apache2
```

The operating system should also be regularly updated:

```
apt update
```

```
apt upgrade
```

The server should follow the principle of least privilege so that a compromised web application cannot obtain unnecessary system privileges.

11. Secure Coding Practices

The application should validate all user input before processing it. Input should be checked for appropriate data type, length, format, and permitted values.

SQL Injection should be prevented by using prepared statements and parameterized queries instead of directly inserting user input into SQL statements.

Cross-Site Scripting should be prevented through proper output encoding. User-generated content should be encoded according to the context in which it is displayed.

Detailed database errors should not be displayed to users. Instead, users should receive generic error messages while detailed errors are stored securely in server logs.

12. Authentication and Session Security

Strong authentication should be implemented throughout the application. Passwords should be stored using secure password-hashing algorithms rather than plaintext storage.

Session IDs should be regenerated after successful authentication and invalidated after logout. Sessions should have appropriate expiration periods.

Cookies should use Secure, HttpOnly, and SameSite attributes. Multi-factor authentication should be implemented for administrator accounts and sensitive financial operations.

13. Web Application Firewall and Network Protection

A Web Application Firewall should be placed in front of the web application. A WAF can detect and block common attacks such as SQL Injection, Cross-Site Scripting, malicious HTTP requests, and directory traversal attempts.

Network firewalls should restrict unnecessary ports and services. The database server should not be directly accessible from the Internet. Network segmentation should be implemented so that the web server, application server, and database server are placed in appropriate security zones.

An Intrusion Detection and Prevention System should also be deployed to detect suspicious activities. Centralized logging and SIEM monitoring can help identify repeated attacks and abnormal account activity.

14. Continuous Monitoring and Testing

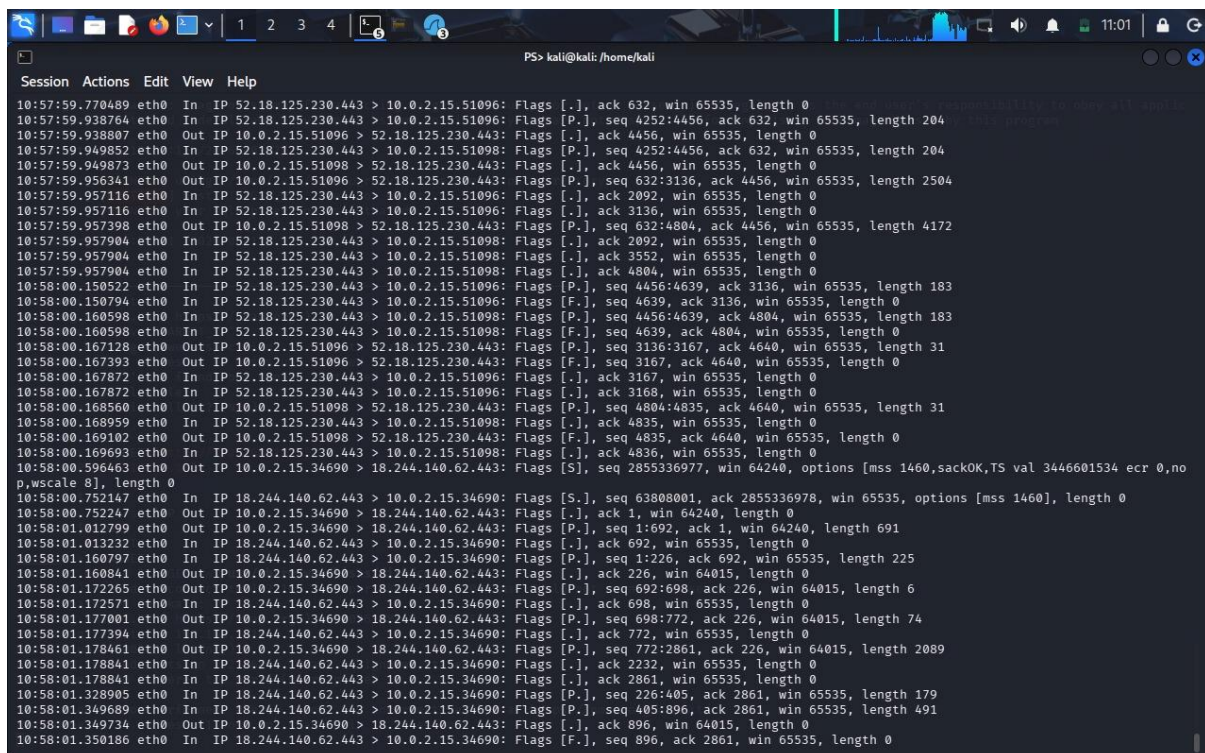
Security should not be treated as a one-time activity. The organization should perform regular vulnerability assessments and penetration tests. Apache logs, authentication logs, WAF logs, and application logs should be continuously monitored.

Security tools such as Nmap, Nikto, Gobuster, Burp Suite, SQLmap, and Nuclei can be used periodically in an authorized testing environment to identify newly introduced vulnerabilities.

Conclusion

The e-commerce application is exposed to significant security risks because of outdated Apache software, inadequate input validation, hidden resources, possible SQL Injection and XSS vulnerabilities, weak application security, and the absence of a WAF. Kali Linux provides useful tools for performing reconnaissance, vulnerability scanning, directory enumeration, and controlled vulnerability validation.

A defense-in-depth approach should be implemented by combining regular software patching, Apache hardening, secure coding, parameterized database queries, output encoding, secure authentication and session management, WAF protection, network segmentation, firewall controls, IDS/IPS, centralized logging, and continuous security testing. Implementing these measures will reduce the probability of successful attacks and protect customer information, transactions, and the availability of the e-commerce application.



```
PS> kali@kali: /home/kali
Session  Actions  Edit  View  Help
10:57:59.770489 eth0 In IP 52.18.125.230.443 > 10.0.2.15.51096: Flags [.], ack 632, win 65535, length 0
10:57:59.938764 eth0 In IP 52.18.125.230.443 > 10.0.2.15.51096: Flags [P.], seq 4252:4456, ack 632, win 65535, length 204
10:57:59.938807 eth0 Out IP 10.0.2.15.51096 > 52.18.125.230.443: Flags [.], ack 4456, win 65535, length 0
10:57:59.949852 eth0 In IP 52.18.125.230.443 > 10.0.2.15.51098: Flags [P.], seq 4252:4456, ack 632, win 65535, length 204
10:57:59.949873 eth0 Out IP 10.0.2.15.51098 > 52.18.125.230.443: Flags [.], ack 4456, win 65535, length 0
10:57:59.956341 eth0 Out IP 10.0.2.15.51096 > 52.18.125.230.443: Flags [P.], seq 632:3136, ack 4456, win 65535, length 2504
10:57:59.957116 eth0 In IP 52.18.125.230.443 > 10.0.2.15.51096: Flags [.], ack 2092, win 65535, length 0
10:57:59.957116 eth0 In IP 52.18.125.230.443 > 10.0.2.15.51096: Flags [.], ack 3136, win 65535, length 0
10:57:59.957398 eth0 Out IP 10.0.2.15.51098 > 52.18.125.230.443: Flags [P.], seq 632:4804, ack 4456, win 65535, length 4172
10:57:59.957904 eth0 In IP 52.18.125.230.443 > 10.0.2.15.51098: Flags [.], ack 2092, win 65535, length 0
10:57:59.957904 eth0 In IP 52.18.125.230.443 > 10.0.2.15.51098: Flags [.], ack 3552, win 65535, length 0
10:57:59.957904 eth0 In IP 52.18.125.230.443 > 10.0.2.15.51098: Flags [.], ack 4804, win 65535, length 0
10:58:00.150522 eth0 In IP 52.18.125.230.443 > 10.0.2.15.51096: Flags [P.], seq 4456:4639, ack 3136, win 65535, length 183
10:58:00.150794 eth0 In IP 52.18.125.230.443 > 10.0.2.15.51096: Flags [F.], seq 4639, ack 3136, win 65535, length 0
10:58:00.160598 eth0 In IP 52.18.125.230.443 > 10.0.2.15.51098: Flags [P.], seq 4456:4639, ack 4804, win 65535, length 183
10:58:00.160598 eth0 In IP 52.18.125.230.443 > 10.0.2.15.51098: Flags [F.], seq 4639, ack 4804, win 65535, length 0
10:58:00.167128 eth0 Out IP 10.0.2.15.51096 > 52.18.125.230.443: Flags [P.], seq 3136:3167, ack 4640, win 65535, length 31
10:58:00.167393 eth0 Out IP 10.0.2.15.51096 > 52.18.125.230.443: Flags [F.], seq 3167, ack 4640, win 65535, length 0
10:58:00.167872 eth0 In IP 52.18.125.230.443 > 10.0.2.15.51096: Flags [.], ack 3167, win 65535, length 0
10:58:00.167872 eth0 In IP 52.18.125.230.443 > 10.0.2.15.51096: Flags [.], ack 3168, win 65535, length 0
10:58:00.168560 eth0 Out IP 10.0.2.15.51098 > 52.18.125.230.443: Flags [P.], seq 4804:4835, ack 4640, win 65535, length 31
10:58:00.168959 eth0 In IP 52.18.125.230.443 > 10.0.2.15.51098: Flags [.], ack 4835, win 65535, length 0
10:58:00.169102 eth0 Out IP 10.0.2.15.51098 > 52.18.125.230.443: Flags [F.], seq 4835, ack 4640, win 65535, length 0
10:58:00.169693 eth0 In IP 52.18.125.230.443 > 10.0.2.15.51098: Flags [.], ack 4836, win 65535, length 0
10:58:00.596463 eth0 Out IP 10.0.2.15.34690 > 18.244.140.62.443: Flags [S], seq 2855336977, win 64240, options [mss 1460,sackOK,TS val 3446601534 ecr 0,no
p,wscale 8], length 0
10:58:00.752147 eth0 In IP 18.244.140.62.443 > 10.0.2.15.34690: Flags [S.], seq 63808001, ack 2855336978, win 65535, options [mss 1460], length 0
10:58:00.752247 eth0 Out IP 10.0.2.15.34690 > 18.244.140.62.443: Flags [.], ack 1, win 64240, length 0
10:58:01.012799 eth0 Out IP 10.0.2.15.34690 > 18.244.140.62.443: Flags [P.], seq 1:692, ack 1, win 64240, length 691
10:58:01.013232 eth0 In IP 18.244.140.62.443 > 10.0.2.15.34690: Flags [P.], ack 692, win 65535, length 0
10:58:01.160797 eth0 In IP 18.244.140.62.443 > 10.0.2.15.34690: Flags [P.], seq 1:226, ack 692, win 65535, length 225
10:58:01.160841 eth0 Out IP 10.0.2.15.34690 > 18.244.140.62.443: Flags [.], ack 226, win 64015, length 0
10:58:01.172265 eth0 Out IP 10.0.2.15.34690 > 18.244.140.62.443: Flags [P.], seq 692:698, ack 226, win 64015, length 6
10:58:01.172571 eth0 In IP 18.244.140.62.443 > 10.0.2.15.34690: Flags [.], ack 698, win 65535, length 0
10:58:01.177001 eth0 Out IP 10.0.2.15.34690 > 18.244.140.62.443: Flags [P.], seq 698:772, ack 226, win 64015, length 74
10:58:01.177394 eth0 In IP 18.244.140.62.443 > 10.0.2.15.34690: Flags [.], ack 772, win 65535, length 0
10:58:01.178461 eth0 Out IP 10.0.2.15.34690 > 18.244.140.62.443: Flags [P.], seq 772:2861, ack 226, win 64015, length 2089
10:58:01.178841 eth0 In IP 18.244.140.62.443 > 10.0.2.15.34690: Flags [.], ack 2232, win 65535, length 0
10:58:01.178841 eth0 In IP 18.244.140.62.443 > 10.0.2.15.34690: Flags [.], ack 2861, win 65535, length 0
10:58:01.328905 eth0 In IP 18.244.140.62.443 > 10.0.2.15.34690: Flags [P.], seq 226:405, ack 2861, win 65535, length 179
10:58:01.349689 eth0 In IP 18.244.140.62.443 > 10.0.2.15.34690: Flags [P.], seq 405:896, ack 2861, win 65535, length 491
10:58:01.349734 eth0 Out IP 10.0.2.15.34690 > 18.244.140.62.443: Flags [.], ack 896, win 64015, length 0
10:58:01.350186 eth0 In IP 18.244.140.62.443 > 10.0.2.15.34690: Flags [F.], seq 896, ack 2861, win 65535, length 0
```

2. A financial services web application allows users to log in, view account details, and perform transactions. A recent penetration test revealed that the application is vulnerable to SQL injection and Cross-Site Scripting (XSS) attacks. Error messages expose database structure information, and user inputs are not properly sanitized. Attackers have exploited these weaknesses to extract sensitive customer data and inject malicious scripts into web pages viewed by other users. You are assigned to perform a detailed security audit of the application. Question: Examine how SQL injection and XSS vulnerabilities can be exploited in this

scenario. Describe a step-by-step methodology using Kali Linux tools such as Burp Suite and SQLmap to identify and validate these vulnerabilities. Evaluate the impact of such attacks on confidentiality, integrity, and availability (CIA triad). Recommend comprehensive mitigation strategies, including input validation, output encoding, secure session handling, and implementation of security controls.

Answer:

SECURITY AUDIT OF A FINANCIAL SERVICES WEB APPLICATION

Introduction

A financial services web application allows customers to log in, view account details, and perform financial transactions. The recent penetration test identified serious SQL Injection and Cross-Site Scripting (XSS) vulnerabilities. The application also exposes database information through error messages and does not properly validate or sanitize user input. These weaknesses can allow attackers to steal confidential customer information, compromise user accounts, and perform unauthorized actions.

A detailed security audit should identify how these vulnerabilities can be exploited, determine their impact, and recommend appropriate security controls. Kali Linux tools such as Burp Suite and SQLmap can be used to identify and validate the vulnerabilities in an authorized testing environment.

1. SQL Injection Vulnerability

SQL Injection occurs when an application directly places user input into a database query without proper validation or parameterization. In a financial application, vulnerable parameters may include account numbers, customer IDs, transaction IDs, search fields, or login fields.

For example, an insecure application may construct a query using user input directly. An attacker can manipulate the input so that the original SQL query behaves differently from its intended purpose.

The consequences can include unauthorized access to customer records, exposure of account information, modification of financial data, and in severe cases, compromise of the underlying database.

2. XSS Vulnerability

Cross-Site Scripting occurs when an application accepts user-controlled input and displays it on a web page without proper output encoding.

For example, an attacker may submit a malicious JavaScript test payload through a vulnerable input field. If the application returns the input without encoding, the browser may execute it as JavaScript.

A harmless XSS test payload in an authorized environment is:

XSS can be particularly dangerous in a financial application because malicious scripts may execute when other users view the affected page. Depending on the application's session and security controls, attackers may attempt to perform actions using a victim's authenticated session or manipulate the content displayed to the victim.

3. Reconnaissance and Application Discovery

The first stage of the security audit is reconnaissance. The tester identifies the application server, open ports, technologies, and web-server information.

Nmap can be used to identify services:

```
nmap -sV -sC TARGET_IP
```

WhatWeb can identify web technologies:

```
whatweb http://TARGET_IP
```

HTTP headers can be inspected using:

```
curl -I http://TARGET_IP
```

The information obtained during this stage helps identify the application's attack surface.

4. Burp Suite Testing

Burp Suite is one of the most useful tools for testing web applications. It can intercept HTTP and HTTPS requests between the browser and the application.

Burp Suite can be started in Kali Linux using:

```
burpsuite
```

The browser is configured to use the Burp Suite proxy, normally through:

```
127.0.0.1:8080
```

The tester then logs into the authorized test account and performs normal application activities such as viewing account details and submitting forms.

Burp Suite HTTP History can be used to identify requests containing parameters such as username, account ID, customer ID, transaction ID, and search values.

The requests can be sent to Burp Repeater, where parameters can be modified and the application's responses can be compared.

5. SQL Injection Identification Using Burp Suite

The tester first identifies parameters that are used by the application to retrieve database information. A harmless SQL syntax test can be entered into an authorized test parameter.

For example:

,

The tester observes whether the application returns database errors, unusual responses, or changes in behavior.

Error messages containing information such as database names, table names, SQL statements, or database server details indicate that the application may be exposing internal information.

The same request can then be sent to Burp Repeater for controlled validation.

6. SQLmap Testing

SQLmap can automatically test an authorized URL parameter for SQL Injection.

Example command:

```
sqlmap -u "http://TARGET_IP/account.php?id=1" -p id --batch
```

SQLmap can also test a captured request exported from Burp Suite:

```
sqlmap -r request.txt --batch
```

If SQL Injection is confirmed, the tester can identify the available databases in the authorized test environment:

```
sqlmap -u "http://TARGET_IP/account.php?id=1" --dbs --batch
```

The tester should limit testing to the minimum required to demonstrate the vulnerability and should not extract real customer or financial information.

7. XSS Identification Using Burp Suite

Burp Suite can also be used to test input fields for XSS. The tester submits a harmless test value through fields such as search boxes, profile information, comments, or transaction descriptions.

A controlled test payload is:

The request can be intercepted in Burp Proxy and sent to Repeater.

If the application returns the input without encoding and the browser executes the script, the parameter is vulnerable to XSS.

The tester should determine whether the vulnerability is reflected, stored, or DOM-based.

8. Error Message Analysis

The application is reported to expose database structure information through error messages. This can help attackers understand the database architecture and construct more effective attacks.

For example, error messages may reveal:

Database type

Database name

Table names

Column names

SQL query structure

File paths

Server information

Detailed technical errors should therefore be disabled in production. Users should receive generic error messages while detailed information should be recorded securely in server-side logs.

9. Impact on CIA Triad

Confidentiality

SQL Injection can allow attackers to access confidential customer information, account details, transaction records, and other sensitive financial data. XSS can also expose sensitive information through compromised user sessions or malicious browser actions.

Integrity

SQL Injection can allow unauthorized modification of database records if the application database account has excessive privileges. Attackers could potentially alter account information or transaction-related records. XSS can allow attackers to manipulate the content displayed to users or perform unauthorized actions through a compromised session.

Availability

Although SQL Injection and XSS primarily threaten confidentiality and integrity, they can also affect availability. Attackers may abuse database queries, application resources, or compromised accounts to disrupt normal application operations.

10. Authentication and Session Security

The financial application must implement strong authentication and secure session management.

Session IDs should be regenerated after successful login. Sessions should expire after a reasonable period of inactivity and should be invalidated after logout.

Session cookies should use the following security attributes:

Secure

HttpOnly

SameSite

Multi-factor authentication should be implemented, especially for sensitive financial operations and administrator accounts.

The application should also implement appropriate authorization checks for every account and transaction operation.

11. Input Validation

All user input must be validated on the server side.

Validation should check:

Data type

Length

Allowed characters

Format

Range

Expected values

Input validation should be performed even if client-side validation is already implemented because client-side controls can be bypassed.

12. SQL Injection Prevention

The most important protection against SQL Injection is the use of parameterized queries or prepared statements.

The application should never construct SQL queries by directly concatenating user input.

Instead, prepared statements should be used so that user input is treated as data rather than executable SQL commands.

The database account used by the application should also have only the permissions required by the application. Excessive database privileges should be avoided.

13. XSS Prevention and Output Encoding

The application should encode user-controlled output before displaying it in HTML pages.

Output encoding must be appropriate for the context, such as HTML, HTML attributes, JavaScript, CSS, or URL contexts.

A strong Content Security Policy should also be implemented to reduce the impact of XSS vulnerabilities.

User-generated content should be handled carefully, and unnecessary HTML or JavaScript should not be allowed.

14. Web Application Firewall and Security Controls

A Web Application Firewall can provide an additional layer of protection against SQL Injection, XSS, and other malicious HTTP requests.

Other recommended security controls include:

Web Application Firewall

Intrusion Detection and Prevention System

Rate limiting

Multi-factor authentication

Secure logging

Security monitoring

Vulnerability scanning

Regular penetration testing

Network segmentation

Database access restrictions

The WAF should be considered an additional layer of defense and should not replace secure application development.

15. Secure Error Handling

Detailed database and application errors should never be displayed to customers.

Instead of displaying technical errors, the application should display a simple message such as:

"An error occurred. Please try again later."

Detailed error information should be stored securely in server-side logs. Access to these logs should be restricted to authorized administrators.

16. Security Testing and Monitoring

After implementing the security controls, the application should be tested again using Burp Suite, SQLmap, Nmap, and other security tools.

The security team should continuously monitor:

Login failures

Unusual account activity

Repeated SQL errors

Suspicious HTTP requests

XSS attempts

Large numbers of requests

Unauthorized transaction attempts

Security logs should be integrated with a SIEM system where possible so that suspicious activities can be detected quickly.

17. Overall Security Methodology

The complete security audit methodology can be summarized as follows:

Reconnaissance

↓

Service and Technology Identification

↓

Web Application Mapping

↓

Burp Suite Request Analysis



Input Validation Testing



SQL Injection Testing with SQLmap



XSS Testing with Burp Suite



Authentication and Session Testing



Authorization Testing



Impact Assessment



Security Controls Implementation



Re-testing and Verification

Conclusion

The financial services application has serious security weaknesses because of SQL Injection, Cross-Site Scripting, improper input validation, insecure error handling, and potentially weak session management. These vulnerabilities can expose sensitive customer information, compromise account integrity, and disrupt application services.

Kali Linux tools such as Nmap, WhatWeb, Burp Suite, and SQLmap can be used to perform reconnaissance and controlled vulnerability validation. The most important mitigation measures are parameterized SQL queries, strong input validation, context-aware output encoding, secure session management, secure error handling, multi-factor authentication, least-privilege database access, WAF protection, logging, monitoring, and regular security testing.

Implementing these controls using a defense-in-depth approach will significantly reduce the risk of SQL Injection and XSS attacks and provide stronger protection for customer accounts and financial transactions.

```
kali@kali: ~  
Session Actions Edit View Help  
[+] Timeout: 10s  
Starting gobuster in directory enumeration mode  
Progress: 0 / 1 (0.00%)  
2026/08/17 10:55:54 error on running gobuster on http://TARGET_IP/: unable to connect to http://TARGET_IP/: Get "http://TARGET_IP/": dial tcp: lookup TARGE  
T_IP on 8.8.8.8:53: no such host  
Command 'nuclei' not found, but can be installed with:  
sudo apt install nuclei  
Do you want to install it? (N/y)n  
[warning] /usr/bin/burpsuite: No JAVA_CMD set for run_java, falling back to JAVA_CMD = java  
Your JRE appears to be version 21.0.9 from Debian  
Burp has not been fully tested on this platform and you may experience problems. java: warning:  
SLF4J: No SLF4J providers were found.  
SLF4J: Defaulting to no-operation (NOP) logger implementation  
SLF4J: See https://www.slf4j.org/codes.html#noProviders for further details.  
libEGL warning: DRI3 error: Could not get DRI3 device  
libEGL warning: Ensure your X server supports DRI3 to get accelerated rendering  
[GFX1-]: RenderCompositorSWGL failed mapping default framebuffer, no dt  
Deleting temporary files - please wait ... done.  
curl: (6) Could not resolve host: TARGET_IP  
curl: (6) Could not resolve host: TARGET_IP  
% Total % Received % Xferd Average Speed Time Time Time Current  
Dload Upload Total Spent Left Speed  
0 0 0 0 0 0 0 0 --:--:-- --:--:-- --:--:-- 0curl: (6) Could not resolve host: TARGET_IP  
curl: (6) Could not resolve host: TARGET_IP  
curl: (6) Could not resolve host: TARGET_IP  
Guide and Answers Mailing List SharkFeed WireShark Donate  
Discord  
{1.9.11#stable}  
https://sqlmap.org  
No Packets Profile Default  
[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applic  
able local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program  
[*] starting @ 10:58:02 /2026-08-17/  
[10:58:03] [CRITICAL] host 'TARGET_IP' does not exist  
[10:58:03] [WARNING] your sqlmap version is outdated  
[*] ending @ 10:58:03 /2026-08-17/
```

3. A corporate office provides wireless internet access to employees using WPA2-PSK authentication. Recently, several employees reported unusual login prompts and slow network performance. A security investigation revealed the presence of a rogue access point (Evil Twin) mimicking the official network SSID. Attackers used this setup to capture login credentials and perform man-in-the-middle (MITM) attacks. You are tasked with analyzing the breach and strengthening wireless security. Explain how the attacker successfully executed the Evil Twin attack and intercepted sensitive data. Describe how Kali Linux tools such as Aircrack-ng and Wireshark can be used to detect and analyze such attacks. Evaluate the weaknesses in the existing wireless security configuration. Propose robust countermeasures, including secure authentication mechanisms, network monitoring, and user awareness strategies.

Answer:

ROGUE ACCESS POINT (EVIL TWIN) ATTACK AND WIRELESS SECURITY

Introduction

An Evil Twin attack occurs when an attacker creates a fake Wi-Fi access point using the same SSID as the legitimate corporate network. Employees may unknowingly connect to the fake network and expose their credentials and sensitive information.

1. Evil Twin Attack

The attacker first observes the corporate Wi-Fi network and identifies its SSID, channel, and BSSID. The attacker then creates a rogue access point with the same SSID. Since WPA2-PSK uses a shared password, users may connect to the stronger-looking or more easily accessible rogue signal.

Once connected, the attacker can monitor network traffic and attempt to capture login credentials or perform MITM attacks. Unencrypted HTTP traffic and poorly secured applications are especially vulnerable.

2. Detection Using Kali Linux

Aircrack-ng can be used to identify nearby wireless networks and detect duplicate SSIDs.

```
sudo airmon-ng start wlan0
```

```
sudo airodump-ng wlan0mon
```

The security analyst should compare the BSSID, channel, signal strength, and manufacturer of access points using the same SSID.

Wireshark can be used to analyze captured wireless traffic:

```
wireshark wifi_capture.pcap
```

Useful filters include:

```
wlan.fc.type_subtype == 0x08
```

for beacon frames, and:

```
wlan.fc.type_subtype == 0x0b
```

for authentication frames.

3. Weaknesses in Existing Security

The main weaknesses are:

- WPA2-PSK uses a shared password.
- Employees can connect to unauthorized access points.
- Lack of rogue AP monitoring.
- No strong enterprise authentication.
- Insufficient network segmentation.
- Lack of employee security awareness.
- Sensitive traffic may not be properly encrypted.

4. Countermeasures

The organization should replace WPA2-PSK with **WPA2-Enterprise or WPA3-Enterprise** using 802.1X and RADIUS authentication. Each employee should have individual credentials rather than sharing one Wi-Fi password.

Protected Management Frames (802.11w/PMF) should be enabled where supported. Wireless IDS/IPS should continuously monitor for rogue access points and suspicious wireless activity.

The network should also use VLAN segmentation, firewalls, VPNs for sensitive communication, and strong HTTPS/TLS protection.

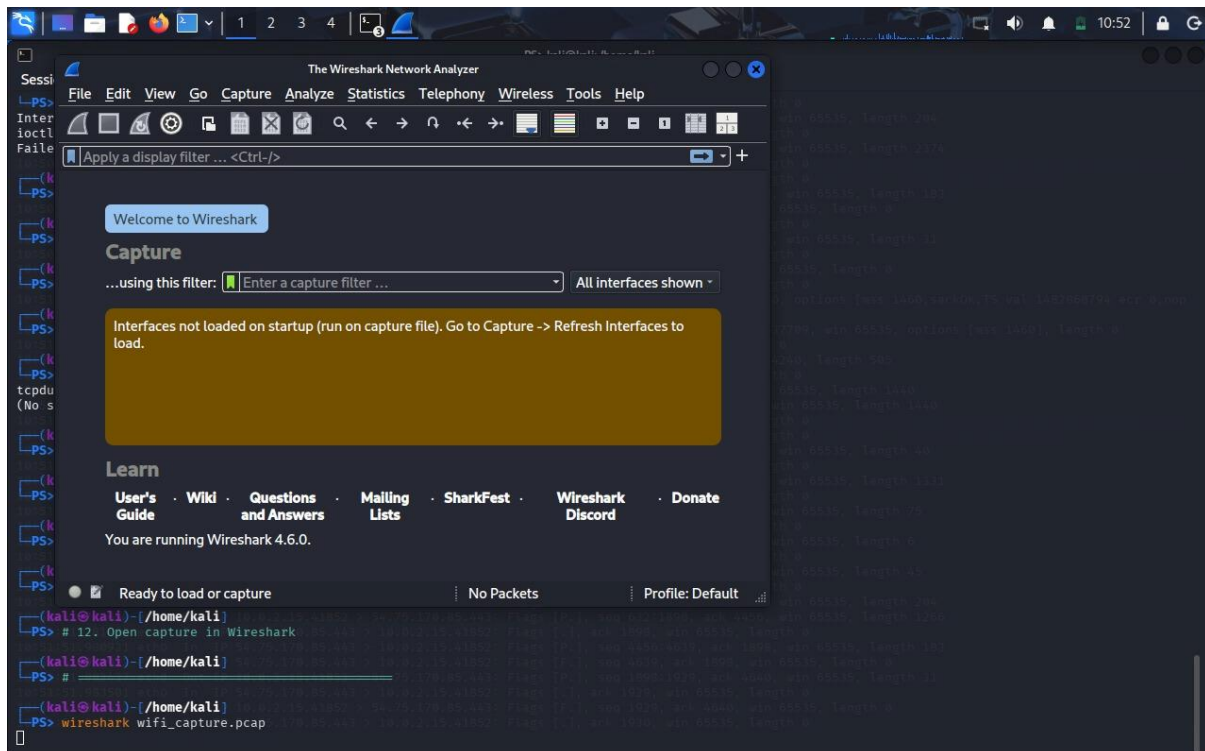
5. User Awareness

Employees should be trained to:

- Verify the correct corporate Wi-Fi network.
- Report unexpected login prompts.
- Avoid entering passwords into suspicious Wi-Fi portals.
- Never ignore browser certificate/security warnings.
- Report unusual network behavior to IT staff.

Conclusion

The Evil Twin attack was possible because users could connect to a rogue access point using the same SSID as the legitimate network. Strong enterprise authentication, WPA3, PMF, wireless monitoring, network segmentation, encryption, and employee awareness can significantly reduce the risk of Evil Twin and MITM attacks.



4. An organization's internal network hosts a web-based employee management system accessible over Wi-Fi. The wireless network uses weak passwords, and the web application lacks proper authentication and session management. An attacker gains access to the Wi-Fi network, performs reconnaissance, and exploits vulnerabilities in the web application to escalate privileges and access confidential employee data. You are assigned to perform a full penetration testing assessment. Analyze the attack chain starting from wireless network compromise to web application exploitation. Describe each phase of the attack, including reconnaissance, scanning, exploitation, and privilege escalation. Demonstrate how Kali Linux tools can be used in each phase. Propose a comprehensive security framework that addresses both wireless and web application vulnerabilities, ensuring defense-in-depth.

Answer:

PENETRATION TESTING OF AN INTERNAL EMPLOYEE MANAGEMENT SYSTEM

Introduction

The organization's internal network contains a web-based employee management system that can be accessed through Wi-Fi. The wireless network uses weak passwords, while the web application has weaknesses in authentication and session management. An attacker can exploit these weaknesses to gain access to the wireless network and then target the internal web application. The complete attack can involve wireless compromise, reconnaissance, scanning, exploitation, privilege escalation, and unauthorized access to confidential employee information.

1. Wireless Network Compromise

The attacker first identifies available wireless networks and determines the target SSID, BSSID, channel, and security configuration. Kali Linux tools such as Aircrack-ng can be used for authorized wireless security assessment.

Commands:

```
iw dev
```

```
sudo airmon-ng start wlan0
```

```
sudo airodump-ng wlan0mon
```

If the WPA2-PSK password is weak, it can be tested in an isolated authorized laboratory environment using an appropriate wordlist.

```
aircrack-ng -w /usr/share/wordlists/rockyou.txt capture.cap
```

If the password is successfully compromised, the attacker may gain access to the internal network.

2. Reconnaissance

After gaining authorized access to the test network, reconnaissance is performed to identify active systems and determine the internal network range.

Commands:

```
ip addr
```

```
ip route
```

```
sudo nmap -sn 192.168.1.0/24
```

This process helps identify the employee management server and other devices connected to the internal network.

3. Network Scanning

After identifying the target server, Nmap can be used to identify open ports and running services.

Commands:

```
sudo nmap -sV -sC TARGET_IP
```

```
sudo nmap -p- TARGET_IP
```

The scan may identify services such as HTTP, HTTPS, SSH, database services, and other exposed services. Unnecessary services should be disabled to reduce the attack surface.

4. Web Application Enumeration

The employee management application is then examined for technologies, directories, and possible vulnerabilities. Kali Linux tools such as WhatWeb, Nikto, and Gobuster can be used.

Commands:

```
whatweb http://TARGET_IP
```

```
nikto -h http://TARGET_IP
```

```
gobuster dir -u http://TARGET_IP -w /usr/share/wordlists/dirb/common.txt
```

These tools can identify application technologies, insecure configurations, hidden directories, and potentially exposed resources.

5. Web Application Testing

Burp Suite can be used to analyze the communication between the browser and the employee management application.

Command:

```
burpsuite
```

The tester can use Burp Proxy to capture HTTP requests and Burp Repeater to test requests in a controlled environment. Login requests, session cookies, employee pages, and administrative functions should be examined.

The tester should check whether protected pages can be accessed without authentication and whether session tokens are properly protected.

6. Exploitation

If vulnerabilities are identified, they should be validated in the authorized test environment. Possible vulnerabilities may include weak authentication, insecure session management, SQL Injection, Cross-Site Scripting, and broken access control.

The purpose of exploitation is to confirm the vulnerability and determine its impact. Real employee information should not be accessed or modified during testing. Dummy accounts and test data should be used.

7. Privilege Escalation

After obtaining access using a normal test account, the tester checks whether the account can access administrator functions without proper authorization.

Examples of protected resources include:

/dashboard

/admin

/admin/users

/admin/reports

Burp Suite Repeater can be used to modify authorized requests and determine whether the server correctly checks the user's privileges.

If a normal employee account can access administrator functions, the application has a broken access-control or privilege-escalation vulnerability.

8. Confidential Data Exposure

If proper authorization controls are not implemented, an attacker may access confidential employee information such as names, contact details, salary information, employee records, and other sensitive data.

During a penetration test, only dummy information should be used to demonstrate the vulnerability.

9. Impact on Security

Confidentiality is affected when unauthorized users gain access to confidential employee information.

Integrity is affected when attackers are able to modify employee records or application data.

Availability may be affected if attackers gain excessive privileges and modify or disrupt important application resources.

Therefore, the combination of weak wireless security and insecure web application controls creates a serious security risk.

10. Wireless Security Measures

The organization should replace weak WPA2-PSK authentication with WPA2-Enterprise or WPA3-Enterprise authentication. 802.1X and RADIUS should be used to provide individual employee authentication instead of a shared password.

Protected Management Frames should be enabled where supported. Wireless IDS/IPS should also be deployed to detect rogue access points and suspicious wireless activity.

Employee and guest networks should be separated using VLANs so that guest devices cannot directly access internal employee systems.

11. Web Application Security Measures

The application should implement strong authentication and role-based access control. Multi-factor authentication should be enabled for administrator and other sensitive accounts.

Secure session management should include session expiration, session invalidation after logout, and regeneration of session IDs after authentication.

Session cookies should use the Secure, HttpOnly, and SameSite security attributes.

All user input should be validated on the server side. Parameterized queries should be used to prevent SQL Injection, and proper output encoding should be implemented to prevent Cross-Site Scripting.

HTTPS should be used to protect communication between users and the web application.

12. Network Security

A defense-in-depth architecture should be implemented:

Internet

Firewall

Wireless Access Points

WPA2/WPA3-Enterprise and 802.1X

Network Segmentation and VLANs

Web Application

Database Server

The database server should not be directly accessible from employee devices. Firewalls should restrict unnecessary connections, and IDS/IPS should monitor suspicious network activity.

13. Monitoring and Security Testing

The organization should continuously monitor wireless activity, authentication logs, web-server logs, firewall events, and application activity. A SIEM system can be used to correlate security events and generate alerts for suspicious behavior.

Regular vulnerability assessments and penetration tests should be performed using tools such as Nmap, Nikto, Gobuster, Burp Suite, and Aircrack-ng in authorized environments.

Conclusion

The attack begins with compromise of the weak wireless password and continues through internal reconnaissance, network scanning, web application enumeration, exploitation, and privilege escalation. Weak wireless authentication combined with poor web authentication and session management can allow attackers to access confidential employee information.

A defense-in-depth approach should therefore be implemented using WPA2-Enterprise or WPA3-Enterprise, 802.1X authentication, network segmentation, strong authentication, secure session management, role-based access control, secure coding practices, firewalls, IDS/IPS, wireless monitoring, and continuous security testing. These measures will significantly reduce the risk of unauthorized access and protect the organization's internal network and employee information.

```
kali@kali: ~  
Session Actions Edit View Help  
Do you want to install it? (N/y)n  
  
(kali@kali)~$ export TARGET="http://192.168.1.10"  
export IP="192.168.1.10"  
curl -I $TARGET  
sudo nmap -sV -sC $IP  
whatweb $TARGET  
nikto -h $TARGET  
nuclei -u $TARGET  
gobuster dir -u $TARGET -w /usr/share/wordlists/dirb/common.txt  
curl: (7) Failed to connect to 192.168.1.10 port 80 after 21008 ms: Could not connect to server  
[sudo] password for kali:  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-17 11:01 EDT  
Nmap scan report for 192.168.1.10  
Host is up (0.00086s latency).  
All 1000 scanned ports on 192.168.1.10 are in ignored states.  
Not shown: 1000 filtered tcp ports (no-response)  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 17.52 seconds  
ERROR Opening: http://192.168.1.10 - execution expired  
- Nikto v2.5.0  
  
+ 0 host(s) tested  
Command 'nuclei' not found, but can be installed with:  
sudo apt install nuclei  
Do you want to install it? (N/y)n  
  
Gobuster v3.8  
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)  
[+] Url: http://192.168.1.10  
[+] Method: GET  
[+] Threads: 10  
[+] Wordlist: /usr/share/wordlists/dirb/common.txt  
[+] Negative Status codes: 404  
[+] User Agent: gobuster/3.8  
[+] Timeout: 10s  
  
Starting gobuster in directory enumeration mode
```

5. A university campus experiences frequent Wi-Fi disruptions during peak hours. Investigation reveals repeated reauthentication attacks targeting access points, causing legitimate users to disconnect. The attacker uses automated tools to continuously send deauth packets, leading to denial of service. You are tasked with identifying the cause and implementing solutions. Explain how reauthentication attacks are carried out in wireless networks and how attackers exploit protocol weaknesses. Describe how Kali Linux tools can be used to simulate and analyse such attacks in a controlled environment. Evaluate the impact on network availability and user productivity. Recommend effective mitigation strategies, including network configuration changes, intrusion detection systems, and secure wireless protocols.

Answer:

DEAUTHENTICATION ATTACK ON UNIVERSITY WI-FI NETWORK

Introduction

A university campus is experiencing frequent Wi-Fi disconnections because attackers are repeatedly sending deauthentication packets to wireless access points and connected users. A deauthentication attack is a type of wireless Denial-of-Service (DoS) attack that abuses weaknesses in IEEE 802.11 management frames. The attack forces legitimate devices to disconnect from the wireless network, reducing network availability and affecting students, teachers, and staff.

1. Deauthentication Attack

In a normal Wi-Fi network, access points and wireless clients exchange management frames to establish and maintain connections. In older or improperly protected configurations, deauthentication frames are not sufficiently authenticated.

An attacker can exploit this weakness by sending forged deauthentication frames that appear to come from the legitimate access point. When a client receives the frame, it may believe that the connection has been terminated and disconnect from the network.

By repeatedly sending these packets, the attacker can continuously disconnect users and create a Denial-of-Service condition.

2. Reconnaissance Using Kali Linux

Kali Linux can be used to identify nearby wireless networks and analyze their security configuration.

Commands:

```
iw dev
```

```
sudo airmon-ng start wlan0
```

```
sudo airodump-ng wlan0mon
```

Airodump-ng displays information such as SSID, BSSID, channel, signal strength, and encryption type. The security analyst can use this information to identify the affected access point in an authorized testing environment.

3. Capturing Wireless Traffic

Wireless traffic can be captured for analysis using tcpdump.

Command:

```
sudo tcpdump -i wlan0mon -w deauth_capture.pcap
```

After collecting the required test traffic, the capture can be stopped using Ctrl+C.

The captured file can then be opened using Wireshark:

```
wireshark deauth_capture.pcap
```

4. Analysis Using Wireshark

Wireshark can identify deauthentication frames in the captured traffic.

The following filter can be used:

```
wlan.fc.type_subtype == 0x0c
```

This filter displays deauthentication frames. The analyst can examine the source address, destination address, timestamp, and frequency of the frames.

A large number of deauthentication frames within a short period may indicate a possible deauthentication attack.

Disassociation frames can also be analyzed using:

```
wlan.fc.type_subtype == 0x0a
```

5. Controlled Simulation

Deauthentication attacks should only be simulated in an isolated laboratory environment using test access points and test devices. The purpose of the simulation is to understand how the attack appears in wireless captures and to evaluate the effectiveness of security controls.

During the controlled test, the security team can monitor the wireless network using Airodump-ng and capture traffic using Wireshark. The generated traffic can then be analyzed to identify abnormal management-frame activity.

6. Impact of the Attack

The main impact of a deauthentication attack is loss of network availability.

Students may lose access to online learning platforms, examinations, university portals, and cloud services. Teachers and staff may experience interruptions while accessing university systems.

Continuous disconnections can reduce productivity, increase network support requests, interrupt online classes, and negatively affect important university activities.

7. Security Weaknesses

The attack is possible because traditional Wi-Fi management frames may not provide adequate protection against forged deauthentication messages.

Other weaknesses may include:

Weak wireless security configuration

Lack of Protected Management Frames

Absence of wireless intrusion detection

Poor wireless monitoring

Improper access-point configuration

Lack of network segmentation

8. Mitigation Strategies

The university should enable Protected Management Frames (PMF), based on IEEE 802.11w, wherever supported. PMF helps protect management frames against spoofing and reduces the effectiveness of deauthentication attacks.

The organization should migrate to WPA3 where possible. WPA2-Enterprise or WPA3-Enterprise with 802.1X authentication should be preferred for campus networks rather than a shared password.

A Wireless Intrusion Detection and Prevention System (WIDS/WIPS) should be deployed to monitor wireless traffic and detect abnormal numbers of deauthentication and disassociation frames.

Access points should be regularly updated with the latest firmware and security patches. Wireless channels should also be properly planned to reduce interference and improve network performance.

9. Network Security Improvements

The university should separate different groups using VLANs, such as:

Student Network

Staff Network

Administrative Network

Guest Network

Firewalls should control communication between these networks. Guest users should not have direct access to internal university systems.

10. Monitoring and Incident Response

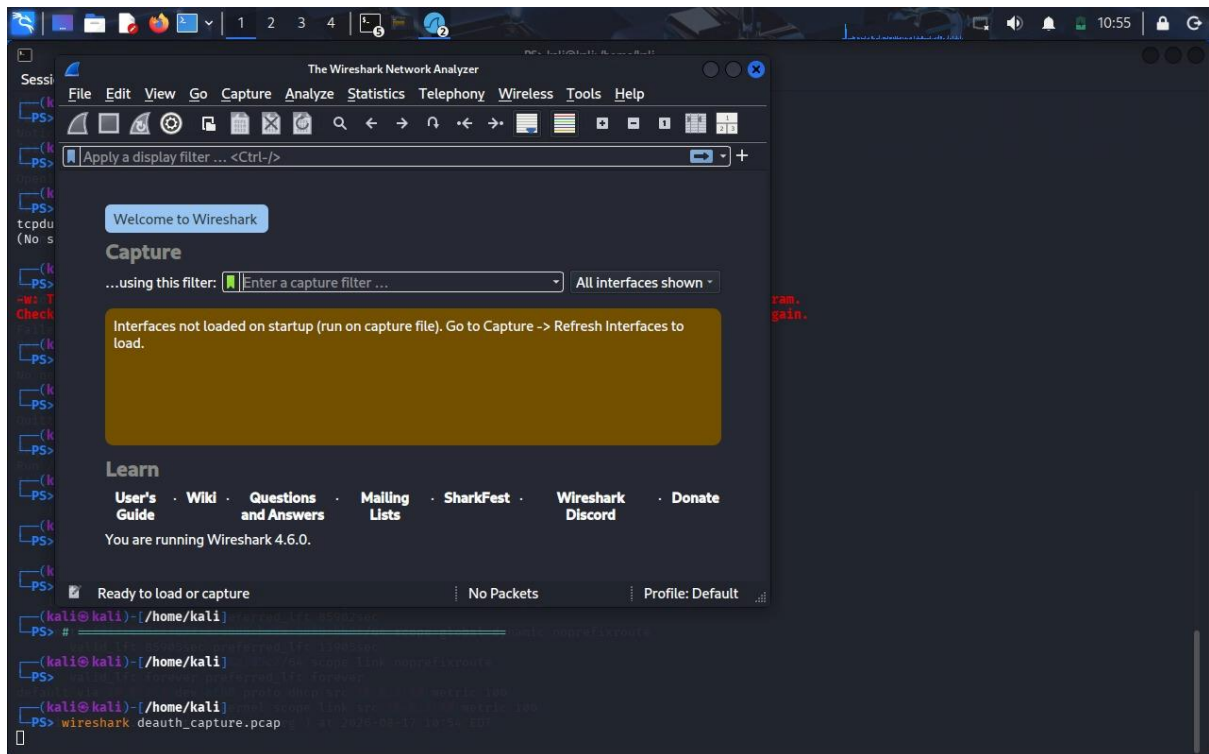
Wireless monitoring should be performed continuously. Security teams should investigate sudden increases in deauthentication frames, unexpected access points, and repeated disconnections.

Logs from access points, wireless controllers, firewalls, and WIDS/WIPS systems should be centralized for analysis. Alerts should be generated when abnormal wireless behavior is detected.

11. Conclusion

Deauthentication attacks exploit weaknesses in wireless management frames to force legitimate users to disconnect from access points. Kali Linux tools such as Aircrack-ng, Airodump-ng, tcpdump, and Wireshark can be used to identify and analyze such attacks in a controlled environment.

The best defense is a combination of Protected Management Frames, WPA2-Enterprise or WPA3-Enterprise, WIDS/WIPS, updated access-point firmware, network segmentation, continuous monitoring, and proper incident response. These measures can significantly improve Wi-Fi availability and reduce the impact of deauthentication-based Denial-of-Service attacks.



Code of Conduct:

I K. Venkata Karthik / 192372092 (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: K. Venkata Karthik